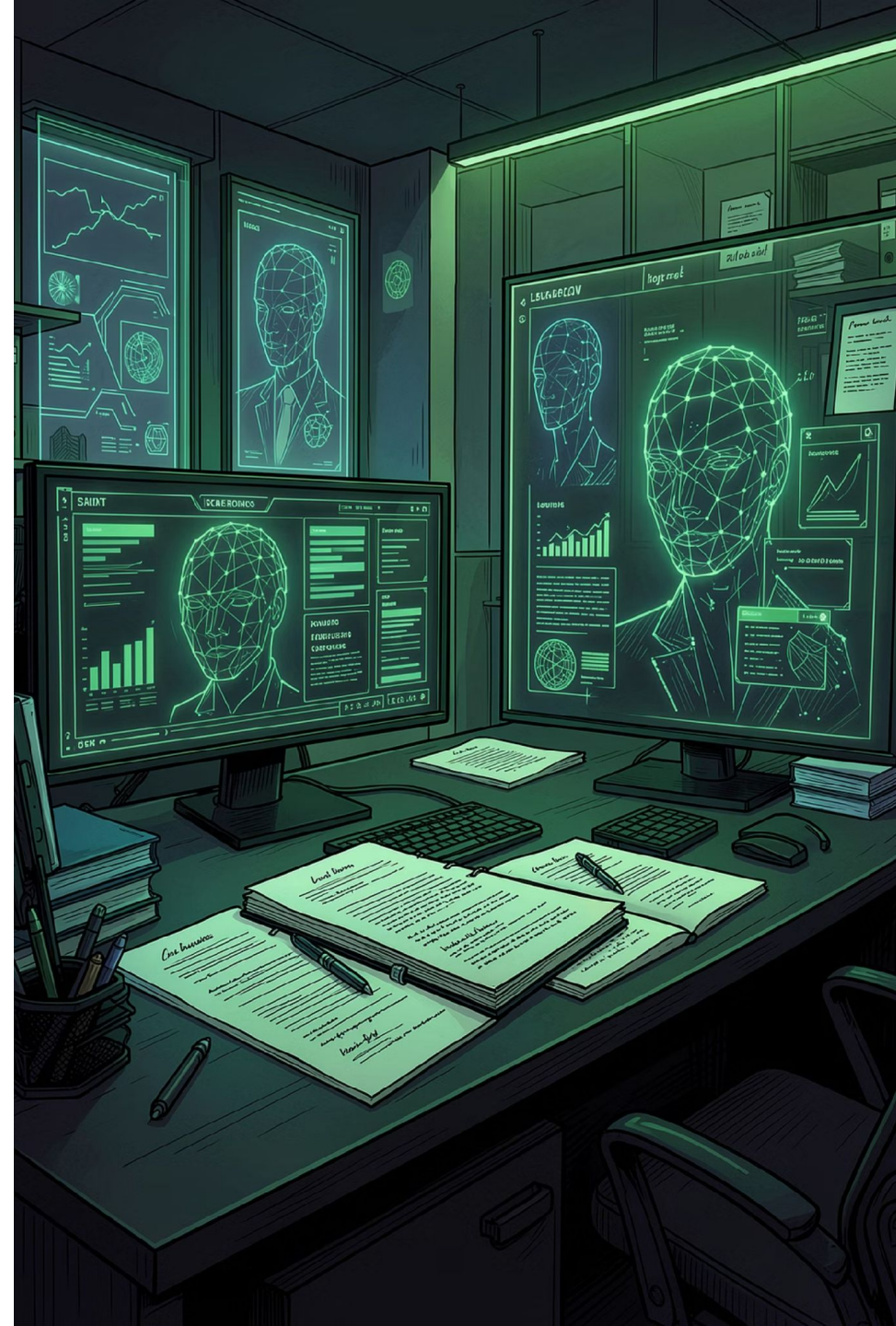


ISI 2026 · INTRODUCCIÓN A LA SEGURIDAD INFORMÁTICA
DOCENTE: ANDRÉS PASTORINI

Análisis de Riesgos — Escenario 11

Plataforma legal con IA generativa (RAG)

Tiago Vescovi





Contexto y alcance del análisis

Plataforma

Firma de servicios profesionales: carga de contratos, consultas RAG, borradores con IA y auditoría de cumplimiento.

Datos críticos

Secreto comercial, datos personales y responsabilidad legal. Alta sensibilidad y exigencia de confidencialidad.

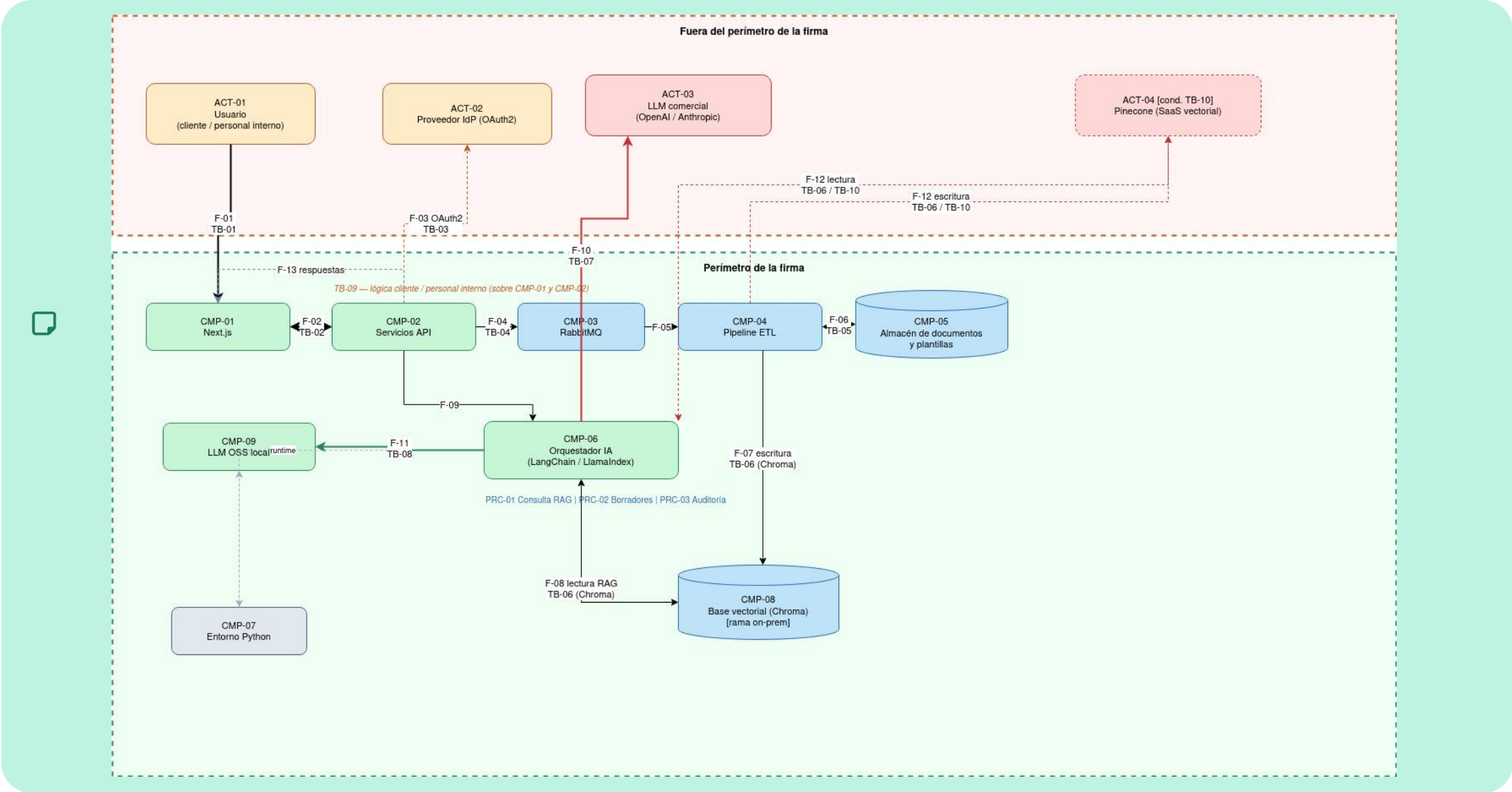
Metodología

Inventario → Arquitectura → STRIDE → DREAD → MITRE ATT&CK → Mitigación → Riesgos residuales.

Entregables

Inventario de activos, arquitectura, análisis STRIDE, matriz DREAD, técnicas ATT&CK, plan de mitigación y riesgo residual.

Arquitectura



Inventario de activos



Información (7)

Documentos legales, corpus de referencia, consultas, respuestas RAG, borradores IA, auditoría, índice vectorial.



Tecnología (8)

Next.js, API, orquestador LangChain/LlamaIndex, vector DB, almacén documentos, LLM cloud, LLM local, RabbitMQ/ETL.



Identidad y procesos

OAuth2, IdP, credenciales técnicas; procesos RAG y borradores/auditoría.



Humanos (5)

Abogados, personal TI, clientes externos, personal administrativo, proveedor cloud/LLM (cadena de suministro).

 Todos los activos críticos alineados al escenario legal con IA.

Análisis STRIDE

STRIDE = Suplantación · Manipulación · Repudio · Divulgación · Denegación · Elevación de privilegios.

Componente	Amenazas	Críticas	Altas	Medias
Usuario	5	0	3	2
Frontend Next.js	6	0	4	2
Backend (API + Orquestador + ETL)	8	3	4	1
Total	19	3	11	5

Amenazas críticas del backend

- Prompt injection en consulta RAG
- Exfiltración de contexto hacia LLM cloud
- Fallo de autorización multi-tenant

Vectores propios de IA/RAG

- Prompt injection y data poisoning
- Retrieval leakage y exfiltración a LLM comercial

Matriz DREAD con priorización

14 amenazas evaluadas · Score = promedio de Daño, Reproducibilidad, Explotabilidad, Usuarios afectados, Detectabilidad.

Id	Componente	Amenaza	Score	Severidad
V1	Usuario	Robo de credenciales / sesión	6,8	Medio
V2	Usuario	Exposición por sesión abierta	6,4	Medio
V3	Usuario	Manipulación de requests (IDOR)	7,8	Alto
V4	Frontend	Over-fetching de datos legales	7,8	Alto
V5	Frontend	Secuestro de sesión (XSS)	6,8	Medio
V6	Frontend	Dependencias comprometidas	7,0	Alto
V7	Backend	Prompt injection en consulta RAG	8,4	Alto
V8	Backend	Exfiltración de contexto hacia LLM cloud	7,8	Alto
V9	Backend	Data poisoning en ingesta	7,0	Alto
V10	Backend	Retrieval leakage (multi-tenant)	7,4	Alto
V11	Backend	Fallo de autorización multi-tenant	7,8	Alto
V12	Backend	Exfiltración en logs del orquestador	7,6	Alto
V13	Backend	Agotamiento de recursos	8,2	Alto
V14	Backend	Inferencias sin trazabilidad	6,4	Medio



Top 3 prioridad: V7 (8,4) · V13 (8,2) · V3/V4/V8/V11 (7,8)

ATT&CK — Escenario hipotético de ataque

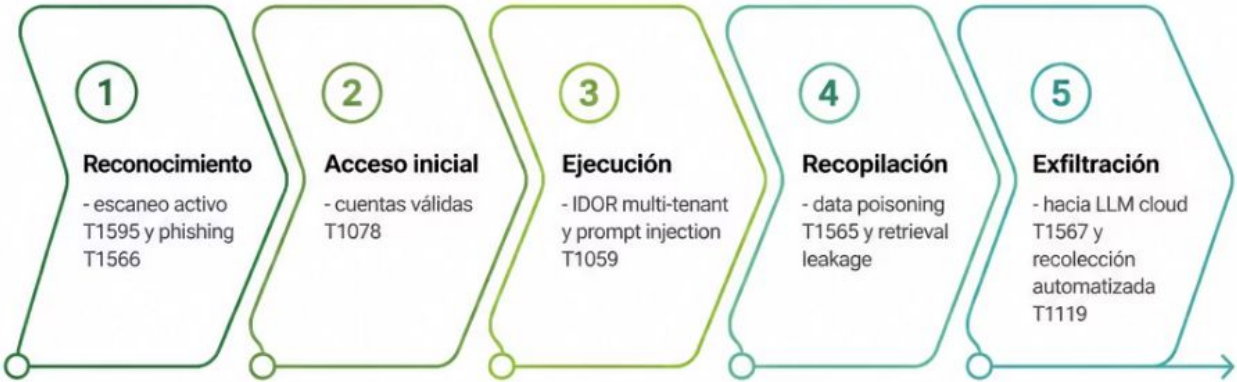
Actor y objetivo

Actor: atacante externo · **Objetivo:** contratos confidenciales y contexto RAG · **Entrada:** portal Next.js y API

Flujo de ataque

- Escaneo y phishing / cuentas válidas (T1595, T1566, T1078)
- IDOR multi-tenant o prompt injection (T1059)
- Data poisoning en ingesta (T1565)
- Retrieval leakage y exfiltración a LLM cloud (T1005, T1567)
- Recolección automatizada vía API (T1119)

 **Componente más crítico:** backend (API + orquestador).



Técnicas MITRE ATT&CK identificadas (11)

T1595 Active Scanning	T1566.002 Phishing	T1078 Valid Accounts	T1059.006 Prompt Injection
T1068 Privilege Escalation	T1005 Data from Local System	T1119 Automated Collection	T1567.002 Exfiltration to Cloud
T1565 Data Manipulation	T1556 Modify Auth	T1070 Indicator Removal	

Riesgos residuales

Tras el plan de mitigación:

0

Alto

Riesgos de nivel alto tras mitigación

11

Medio

Riesgos de nivel medio aceptados

3

Bajo

Riesgos de nivel bajo residuales

0

Crítico

Riesgos críticos eliminados

Patrón dominante: Medio

Configuración, evolución de ataques IA y dependencia operativa.

Riesgos aceptados formalmente

Alucinación del LLM, borradores sin revisión humana, Pinecone SaaS (si aplica).

Responsabilidad intransferible

Transferir riesgo al proveedor cloud no elimina la responsabilidad de la firma.

Recomendaciones principales



1. Acceso

MFA · RBAC · OAuth2 · aislamiento multi-tenant.



2. RAG / IA

Validación de entradas · sanitización de prompts · filtros en recuperación vectorial.



3. Datos sensibles

Enrutar lo crítico al LLM local · preferir Chroma on-prem · cifrado.



4. Proceso

Revisión legal obligatoria de salidas · logging y trazabilidad de inferencias.



Prioridad inmediata: V7 prompt injection · V13 agotamiento de recursos · V8 exfiltración LLM cloud.



Conclusiones

Riesgos concentrados en el backend

Autorización multi-tenant, RAG y salida hacia LLMs externos son los vectores más críticos.

Metodología con base técnica y de negocio

STRIDE + DREAD + ATT&CK permiten priorizar y comunicar riesgos a stakeholders no técnicos.

Defensa en capas

Controles técnicos + enrutamiento por sensibilidad + revisión humana obligatoria.

Sin cero riesgo con IA generativa

Mitigar, documentar y aceptar conscientemente el riesgo residual es la postura responsable.

Gracias · ¿Preguntas?

¿Preguntas?

Gracias por su atención

Tiago Vescovi

Link del repositorio: https://github.com/TiagoVescovi/ISI_Tarea2.git